

Oracle Cloud Compromised

April, 2025

Executive Overview

On 21 March 2025, threat actor rose87168, advertised the sale of over 6 million records allegedly exfiltrated from Oracle Cloud's SSO and LDAP systems. These records reportedly include Java KeyStore (JKS) files, encrypted SSO passwords, key files, and Enterprise Manager JPS configuration keys, suggesting a compromise of sensitive authentication infrastructure.

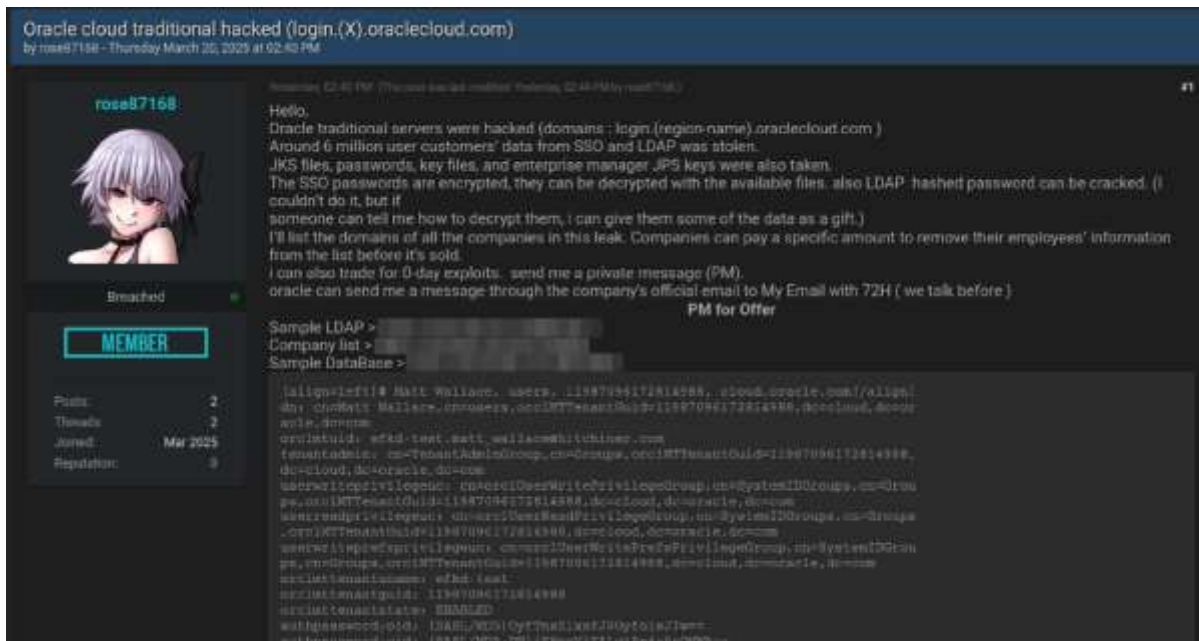
Oracle initially downplayed the incident and dismissed claims of unauthorized access before later conceding that the actor accessed data housed on two legacy servers, while maintaining that its primary cloud environment remained unaffected. This inconsistent communication, paired with the presence of recent data in the leak and the age of the exploited vulnerability, has drawn scrutiny from the cybersecurity community.

Key Points

- Threat actor "rose87168" claims to have breached Oracle's cloud servers, exfiltrating over 6 million records from SSO and LDAP systems. The attacker offered the stolen data for sale and attempting to extort over 140K affected tenants.
- The attacker allegedly exploited a known vulnerability (CVE-2021-35587) in Oracle Fusion Middleware, enabling remote code execution and full compromise of Oracle Access Manager.
- Oracle initially denied any breach of its cloud environment but later admitted that two obsolete servers were compromised servers it claims were never part of Oracle Cloud Infrastructure (OCI). However, multiple cybersecurity experts argue this is a semantic distinction and that the breach still affects Oracle-managed cloud systems.
- Despite Oracle's assurances, leaked data samples have been independently verified by at least three affected customers, including data from active production environments with access to sensitive information. This undermines Oracle's claim that the breach involved only old, non-sensitive credentials.
- The breach involves the exfiltration of critical authentication data that could be exploited for unauthorized access to cloud environments, including potential downstream impacts on critical systems, services, or clients if any shared Oracle infrastructure is involved.

Assessment

Threat actor **rose87168** began selling a massive cache of **6 million records** from Oracle Cloud's SSO (Single Sign-On) and LDAP (Lightweight Directory Access Protocol) systems. These records include sensitive data like JKS files, encrypted SSO passwords, key files, and enterprise manager JPS keys.



Threat actor listing 6M records exfiltrated from Oracle Cloud

How Did It Happen?

The attack seems to have been orchestrated by exploiting a vulnerability in **Oracle Fusion Middleware**, specifically **CVE-2021-35587**, which affects Oracle Access Manager (OAM). This vulnerability was disclosed in 2021 and was added to the CISA Known Exploited Vulnerabilities (KEV) list in December 2022, yet Oracle Cloud Classic remained vulnerable due to outdated patching practices.

The actor is believed to have targeted the **login.us2.oraclecloud.com** endpoint, which had not been updated since 2014, exposing a critical flaw. Using this vulnerability, the actor was able to deploy a web shell and additional malware on Oracle's Gen 1 servers (Oracle Cloud Classic). Once inside, they accessed and exfiltrated credentials from Oracle Identity Manager (IDM), including user emails, hashed passwords, usernames, and other sensitive data.

Threat Actor: rose87168

The breach is attributed to rose87168, a threat actor active since January 2025. This actor appears to be using highly sophisticated tactics, despite having no prior history in cybercrime forums. What sets rose87168 apart is their use of a zero-day vulnerability, which suggests deep knowledge of Oracle's infrastructure and a highly calculated attack strategy.

The actor initially claimed he exploited a zero-day vulnerability, not CVE-2021-35587, and stated that the only Oracle customer data obtained was login data from the SSO service. However, rose87168 sought assistance from others to crack the hashed passwords. The actor first shared data from 2024 and later posted 2025-specific records on Breach Forums, proving the stolen data is recent and still highly relevant to targeted organizations. To escalate pressure, the actor offered incentives for help decrypting the stolen data, such as hashed passwords, and demanded ransom payments to prevent further leaks.

The most concerning element of this breach is the ransom demand. The threat actor has been actively extorting impacted companies, pressuring them to pay for data removal and claiming to have further compromising data in their possession. The actor's demands for cryptocurrency payments and threats of further leaks put Oracle Cloud clients in a difficult position—either comply with the extortion demands or risk having their data further exploited.

The actor claimed he would release data the weekend of 4/5/2025. However, he failed to release anything, raising questions about rose87168's credibility

Oracle's Response

Oracle's response to the breach has been scrutinized. Initially, the company denied any impact on Oracle Cloud (OCI) environments, claiming the breach was limited to legacy infrastructure.



However, as more details emerged, Oracle acknowledged that the breach originated from Oracle Cloud Classic, an older part of their infrastructure still containing client data.

Despite Oracle's attempts to downplay the incident, third-party cybersecurity firms like CloudSEK confirmed that sensitive credentials from active systems were compromised. Additionally, some Oracle clients reported that users with access to production data were among

those affected. The leaked credentials may provide attackers with access to sensitive financial systems, customer information, and internal tools.

Key Intelligence Gaps

- A thorough analysis or description of the extent of the actor's access is needed, as Oracle has provided conflicting statements.
- The complete extent of the data obtained remains undetermined, as rose87168 has only released samples.
- Confirmation on the vulnerability rose87168 exploited as the actor gave conflicting statements on how he gained initial access.

Recommended Mitigations

- Review third-party identity dependencies.
- Enforce MFA across privileged accounts.
- Rotate exposed credentials.
- Monitor for anomalous authentication activity.
- Audit service accounts and privileged access.
- Conduct threat hunting against identified TTPs.
- Validate patch management practices for externally exposed services.

Mitre ATT&CK TABLE

				XYZ Coverage	None	Weak	Medium	Strong
Tactic	Technique	Sub-technique	Procedure					
Initial Access	Exploitation of Public-Facing Application (T1190)		The actor likely exploited CVE-2021-35587 in Oracle Fusion Middleware (Oracle Access Manager), allowing remote code execution and initial access to Oracle Cloud Classic servers.					
Execution	Command and Scripting Interpreter (T1059)		The actor may have used web shells or other forms of remote code execution, leveraging a command-line interface to execute malicious actions on compromised servers.					
Persistence	Web Shell (T1100)		The actor installed a web shell to maintain persistence on Oracle’s infrastructure, allowing continuous access even if initial					

			access points are closed or defenses are improved.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)		The actor might have escalated privileges by exploiting misconfigurations or vulnerabilities in Oracle's authentication mechanisms, such as LDAP or SSO systems.
Defense Evasion	Obfuscated Files or Information (T1027)		The actor may have used encrypted files, such as JKS files or key files , to evade detection and maintain access to sensitive data while bypassing security measures.
Credential Access	Input Capture (T1056)		The stolen SSO credentials and LDAP passwords suggest the actor captured and harvested credentials through exploitation or credential dumping techniques.
	Brute Force (T1110)		The actor could have used brute-forcing or other methods to crack hashed passwords or gain access to encrypted data stored within Oracle Cloud Classic environments.
Discovery	System Information Discovery (T1082)		The actor likely performed system enumeration on compromised systems to understand the environment, identify valuable targets, and prepare for lateral movement or additional attacks.
Lateral Movement	Remote File Copy (T1105)		The actor may have used remote file copying or other methods to move laterally across systems within the compromised environment, potentially accessing additional data or systems.
Collection	Data from Information Repositories (T1213)		The stolen user emails , hashed passwords , enterprise manager keys , and JKS files represent a collection of sensitive data that could be sold or used in subsequent attacks.
Exfiltration	Exfiltration Over C2 Channel (T1041)		The actor exfiltrated large volumes of sensitive data (including 6 million records) likely over a C2 (Command and Control) channel . The stolen data was later shared on BreachForums .
Impact	Data Destruction (T1485)		The actor's ability to exfiltrate and potentially delete or alter data could result in data destruction as part of a more destructive

			payload, especially with the extortion and threat of further leaks.
	Data Manipulation (T1565)		If the stolen data is manipulated or used maliciously (e.g., credential misuse), it can have significant impacts, including system compromise or fraud.

Appendix

Indicator of compromise

IPv4 Addresses

104[.]216[.]216[.]194
 140[.]99[.]215[.]60
 140[.]99[.]215[.]62
 140[.]99[.]22[.]146
 140[.]99[.]22[.]148
 140[.]99[.]22[.]149
 140[.]99[.]22[.]151
 140[.]99[.]22[.]154
 185[.]16[.]205[.]4
 185[.]215[.]181[.]234
 185[.]219[.]141[.]103
 20[.]185[.]225[.]251
 20[.]29[.]242[.]130
 5[.]180[.]208[.]20
 52[.]149[.]229[.]17
 52[.]171[.]127[.]238
 85[.]12[.]29[.]137
 85[.]12[.]29[.]138
 85[.]12[.]29[.]142
 85[.]12[.]61[.]199
 85[.]12[.]61[.]61

IPv6 Addresses

2603[.]10b6[.]510[.]23c
 2603[.]10b6[.]510[.]23d
 2603[.]10b6[.]510[.]2cc
 2603[.]10b6[.]510[.]2cd
 2603[.]10b6[.]510[.]2cf
 2603[.]10b6[.]510[.]2d2
 2603[.]10b6[.]510[.]2d7
 2603[.]10b6[.]510[.]323
 2603[.]10b6[.]510[.]324
 2603[.]10b6[.]510[.]325
 2603[.]10b6[.]510[.]326
 2603[.]10b6[.]510[.]327
 2603[.]10b6[.]510[.]328
 2603[.]10b6[.]510[.]32b
 2603[.]10b6[.]510[.]32c
 2603[.]10b6[.]510[.]32d
 2603[.]10b6[.]510[.]338
 2603[.]10b6[.]510[.]339
 2603[.]10b6[.]510[.]33a
 2603[.]10b6[.]510[.]33b
 2603[.]10b6[.]510[.]33c
 2603[.]10b6[.]510[.]33d
 2603[.]10b6[.]510[.]5

2603[.]10b6[.]510[.]e
 2603[.]10b6[.]518[.]1
 2603[.]10b6[.]a02[.]80
 2603[.]10b6[.]a02[.]a8
 2603[.]10b6[.]a02[.]bc
 2603[.]10b6[.]a02[.]ee
 2603[.]10b6[.]a03[.]100
 2603[.]10b6[.]a03[.]114
 2603[.]10b6[.]a03[.]12b
 2603[.]10b6[.]a03[.]14b
 2603[.]10b6[.]a03[.]167
 2603[.]10b6[.]a03[.]180
 2603[.]10b6[.]a03[.]1a0
 2603[.]10b6[.]a03[.]1b8
 2603[.]10b6[.]a03[.]1d0
 2603[.]10b6[.]a03[.]1e0
 2603[.]10b6[.]a03[.]1f4
 2603[.]10b6[.]a03[.]217
 2603[.]10b6[.]a03[.]254
 2603[.]10b6[.]a03[.]255
 2603[.]10b6[.]a03[.]2c0
 2603[.]10b6[.]a03[.]2c1
 2603[.]10b6[.]a03[.]2

Sources

- <https://www.bleepingcomputer.com/news/security/oracle-says-obsolete-servers-hacked-denies-cloud-breach/>
- <https://www.bleepingcomputer.com/news/security/oracle-privately-confirms-cloud-breach-to-customers/>
- <https://www.bleepingcomputer.com/news/security/oracle-customers-confirm-data-stolen-in-alleged-cloud-breach-is-valid/>
- <https://www.cloudsek.com/blog/the-biggest-supply-chain-hack-of-2025-6m-records-for-sale-exfiltrated-from-oracle-cloud-affecting-over-140k-tenants>
- https://www.linkedin.com/posts/alon-gal-utb_big-i-just-received-10000-records-from-activity-7310017463516127232-XWbl/

